

VindobonaPay GmbH — Risk Register

Asset-based risk assessment (ISO/IEC 27005 / NIST SP 800-30, simplified) | 5x5 matrix | Version 1.0 | Fictional company for educational purposes

Risk ID	Asset	Risk description (threat / vulnerability)	Consequence	Inh. Likelihood	Inh. Impact	Inherent score	Existing controls	Res. Likelihood	Res. Impact	Residual score	Treatment decision	Treatment action / acceptance rationale	Related Annex A controls	Risk Owner	Action Owner	Target date	Status
R-01	Payment platform	DDoS attack against the public payment service; limited anti-DDoS measures beyond cloud defaults.	Service outage, SLA breach, revenue loss and reputational damage.	4	4	16	Azure availability zones redundancy; capacity monitoring (A.8.6, A.8.14).	2	4	8	Mitigate	Enable Azure DDoS Protection on public endpoints and document response runbook.	A.8.6, A.8.14, A.5.30	CTO	IT Manager	Q4 2026	In progress
R-02	Customer payment data	Compromise of a privileged account (stolen credentials); MFA enrollment not yet complete for all admin accounts.	Large-scale breach of payment and personal data; GDPR and regulatory impact.	4	5	20	MFA and Conditional Access (A.8.5); separate admin accounts; quarterly privileged access review partially in place (A.8.2).	2	5	10	Mitigate	Complete MFA enrollment for all privileged accounts and introduce Privileged Identity Management (just-in-time access).	A.8.2, A.8.5, A.5.18	CISO	IT Manager	Q3 2026	In progress
R-03	Employees	Phishing campaign leading to credential theft; staff are a frequent target for a fintech.	Unauthorized access to mailboxes and internal systems; possible fraud attempts.	5	4	20	Yearly awareness training and phishing simulations (A.6.3); mail filtering and EDR (A.8.7).	3	3	9	Mitigate	Introduce phishing-resistant MFA (FIDO2 keys) for administrators and finance staff.	A.6.3, A.8.7, A.8.5	CISO	IT Manager	Q1 2027	Open
R-04	Endpoints	Ransomware infection on a company laptop spreading to shared resources.	Data encryption, operational disruption, potential extortion.	4	5	20	EDR on all endpoints (A.8.7); automated backups with restore tests (A.8.13); MDM hardening (A.8.1).	2	4	8	Mitigate	Extend application allow-listing to all servers and complete endpoint hardening baseline.	A.8.7, A.8.13, A.8.1, A.8.19	CISO	IT Manager	Q4 2026	In progress
R-05	Cloud infrastructure	Misconfiguration of an Azure resource (e.g. storage account exposed to the internet); cloud baselines only partially defined.	Exposure of internal or customer data; regulatory impact.	4	4	16	Endpoint hardening baseline exists; cloud hardening baselines partially defined (A.8.9); Cloud Services Policy (A.5.23).	3	4	12	Mitigate	Complete cloud configuration baselines and enable continuous configuration scanning (Defender for Cloud).	A.8.9, A.5.23	CTO	IT Manager	Q4 2026	In progress
R-06	Critical ICT suppliers	Failure or security incident at a critical ICT service provider; structured supplier reviews not yet in place.	Service disruption and possible data exposure; DORA third-party risk obligations.	3	4	12	Supplier list with risk rating (partial, A.5.19); security clauses in main contracts (A.5.20).	3	3	9	Mitigate	Define ICT supply chain risk procedure and yearly supplier review cycle (DORA-aligned).	A.5.19, A.5.21, A.5.22	Compliance Of	Compliance Of	Q1 2027	Open
R-07	Payroll data	Data breach at the outsourced payroll provider.	Exposure of employee personal and salary data; GDPR notification duties.	3	4	12	Contractual security and breach notification clauses (A.5.20); NDA; provider ISO 27001 certified.	2	3	6	Transfer	Risk transferred contractually: liability and notification duties sit with the provider. Verify provider certification yearly.	A.5.19, A.5.20	CFO	Compliance Of	Q4 2026	Ongoing
R-08	Payment data / internal systems	Insider misuse of legitimate access to payment data; segregation of duties matrix still in draft.	Fraud or data leakage by an internal user; hard to detect without monitoring.	3	5	15	RBAC on payment systems (A.8.3); logging partially centralized (A.8.15); SoD matrix in draft (A.5.3).	2	4	8	Mitigate	Finalize segregation of duties matrix, complete quarterly access reviews and extend log coverage.	A.5.3, A.5.18, A.8.3, A.8.15	CISO	IT Manager	Q4 2026	In progress
R-09	Company laptops	Loss or theft of a laptop during remote/hybrid work.	Potential exposure of locally stored data.	4	3	12	Full-disk encryption on all laptops; MDM remote wipe (A.7.9, A.8.1).	2	2	4	Accept	Residual risk accepted: encryption makes data unreadable and remote wipe is available. Accepted by: CFO. Review: 30 June 2027.	A.7.9, A.8.1	CFO	IT Manager	—	Accepted
R-10	Payment application	Exploitable vulnerability in the in-house payment application.	Fraudulent transactions, data exposure, service disruption.	4	4	16	SAST in the CI pipeline; yearly external penetration test; code review before merge (A.8.25–A.8.29).	3	3	9	Mitigate	Add DAST to the CI pipeline and formalize the secure SDLC procedure.	A.8.25, A.8.26, A.8.28, A.8.29	CTO	Head of Engine	Q1 2027	Open
R-11	Servers and endpoints	Exploitation of unpatched systems; patch SLAs not yet defined by severity.	System compromise via known vulnerabilities.	4	4	16	Monthly vulnerability scans (A.8.8); EDR detection (A.8.7).	3	3	9	Mitigate	Define patch SLAs by severity and track remediation in monthly reports.	A.8.8	CISO	IT Manager	Q3 2026	In progress
R-12	Finance processes	Business email compromise / payment fraud targeting finance staff.	Fraudulent outgoing payments; direct financial loss.	3	4	12	Awareness training (A.6.3); segregation of duties partially in place (A.5.3).	2	4	8	Mitigate	Introduce dual approval for outgoing payments above threshold and a callback verification procedure.	A.5.3, A.6.3	CFO	CFO	Q3 2026	In progress
R-13	IT operations knowledge	Key person dependency in the small IT team; procedures only partially documented.	Operational disruption if key staff are unavailable.	3	3	9	IT runbook in progress (A.5.37); shared admin knowledge for core systems.	3	2	6	Mitigate	Complete documentation of key IT and security procedures.	A.5.37	CTO	IT Manager	Q4 2026	In progress
R-14	Regulatory compliance	Failure to meet DORA/NIS2 incident reporting deadlines; dedicated reporting procedure not yet defined.	Regulatory sanctions and reputational damage with the FMA.	3	4	12	Incident Response Plan with triage criteria (A.5.24); legal & regulatory register (A.5.31).	2	3	6	Mitigate	Define a regulatory incident reporting procedure with DORA timelines (covered in Deliverable 05).	A.5.24, A.5.31	Compliance Of	Compliance Of	Q1 2027	Open
R-15	Server room	Physical intrusion into the office server room.	Theft or tampering of local equipment.	2	3	6	Badge access and visitor register (A.7.2); locked server room (A.7.3); CCTV and alarm (A.7.4).	1	3	3	Accept	Residual risk accepted: physical controls in place and limited on-prem footprint. Accepted by: Management. Review: 31 December 2026.	A.7.1, A.7.2, A.7.3, A.7.4	COO	Office Manager	—	Accepted
R-16	Microsoft 365 services	Prolonged Microsoft 365 outage affecting daily operations.	Temporary loss of email and collaboration tools.	2	4	8	Business Continuity Plan draft (A.5.29); Microsoft SLA; payment platform not dependent on M365.	2	3	6	Accept	Residual risk accepted: multi-cloud setup not cost-justified; core payment service unaffected. Accepted by: CFO. Review: 31 December 2026.	A.5.29, A.5.30	COO	IT Manager	—	Accepted

Risk levels:

Low (1-4)

Medium (5-9)

High (10-15)

Critical (16-25)

Score = Likelihood (1-5) x Impact (1-5). Inherent = before controls; Residual = considering existing controls.

Risk Matrix — 5x5 heat maps

Likelihood (rows, 1-5) x Impact (columns, 1-5). Cells show Risk IDs.

Inherent risk (before controls)

	Impact 1	Impact 2	Impact 3	Impact 4	Impact 5
Likelihood 5				R-03	
Likelihood 4			R-09	R-01, R-05, R-10, R-11	R-02, R-04
Likelihood 3			R-13	R-06, R-07, R-12, R-14	R-08
Likelihood 2			R-15	R-16	
Likelihood 1					

Residual risk (considering existing controls)

	Impact 1	Impact 2	Impact 3	Impact 4	Impact 5
Likelihood 5					
Likelihood 4					
Likelihood 3		R-13	R-03, R-06, R-10, R-11	R-05	
Likelihood 2		R-09	R-07, R-14, R-16	R-01, R-04, R-08, R-12	R-02
Likelihood 1			R-15		

Risk Summary — VindobonaPay GmbH

All values calculated automatically from the Risk Register sheet.

Total risks	16
-------------	----

BY INHERENT LEVEL

Critical (16-25)	7
High (10-15)	6
Medium (5-9)	3
Low (1-4)	0

BY RESIDUAL LEVEL

Critical (16-25)	0
High (10-15)	2
Medium (5-9)	12
Low (1-4)	2

BY TREATMENT DECISION

Mitigate	12
Accept	3
Transfer	1
Avoid	0

Note: no risk remains at Critical residual level. Accepted risks include rationale, approver and review date in the register.